

Universidad Politécnica de San Luis Potosí

Ingeniería en Tecnologías de la Información

ACTIVIDAD 04 - Una página demasiado convincente

Alumno: Edgar Alejandro Valerio Sánchez

Fecha: 31 de agosto de 2026

2. Índice

- 3. Objetivo de la actividad
- 4. Descripción del escenario
- 5. Configuración del laboratorio
- 6. Evidencias y descripción del funcionamiento
- 7. Explicación del flujo de captura de información
- 8. Controles de seguridad propuestos
- 9. Conclusión

3. Objetivo de la actividad

Objetivo general: Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

4. Descripción del escenario

El área de seguridad informática de una organización ha recibido varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales. El mensaje contiene un enlace que dirige a un portal aparentemente institucional. La página incluye logotipo, campos de usuario y contraseña y un mensaje indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar". A primera vista, nada parece fuera de lo común. Sin embargo, el portal no pertenece a la organización.

Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?

Es un vector de ataque utilizado en campañas de ingeniería social que despliega un servidor web malicioso diseñado para interceptar, capturar y almacenar datos confidenciales (como credenciales de acceso) introducidos por una víctima engañada. Su función es recolectar esta información y posteriormente redirigir a la víctima al sitio legítimo o generar una alerta de error genérica para no levantar sospechas.

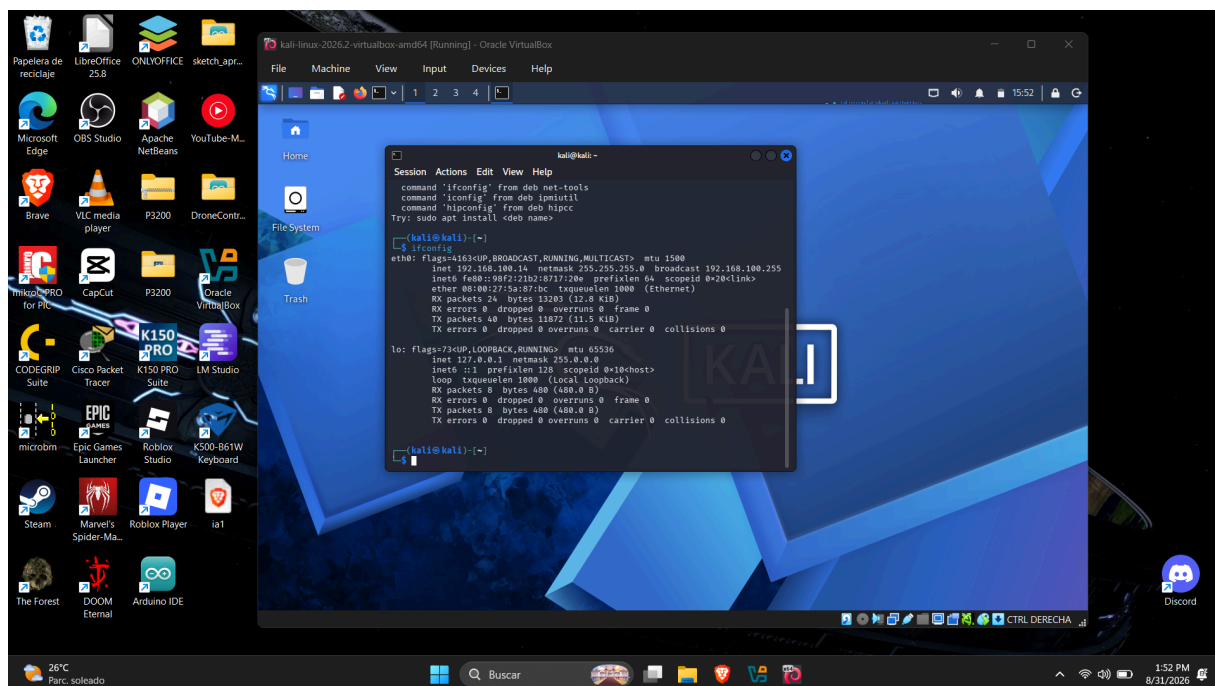
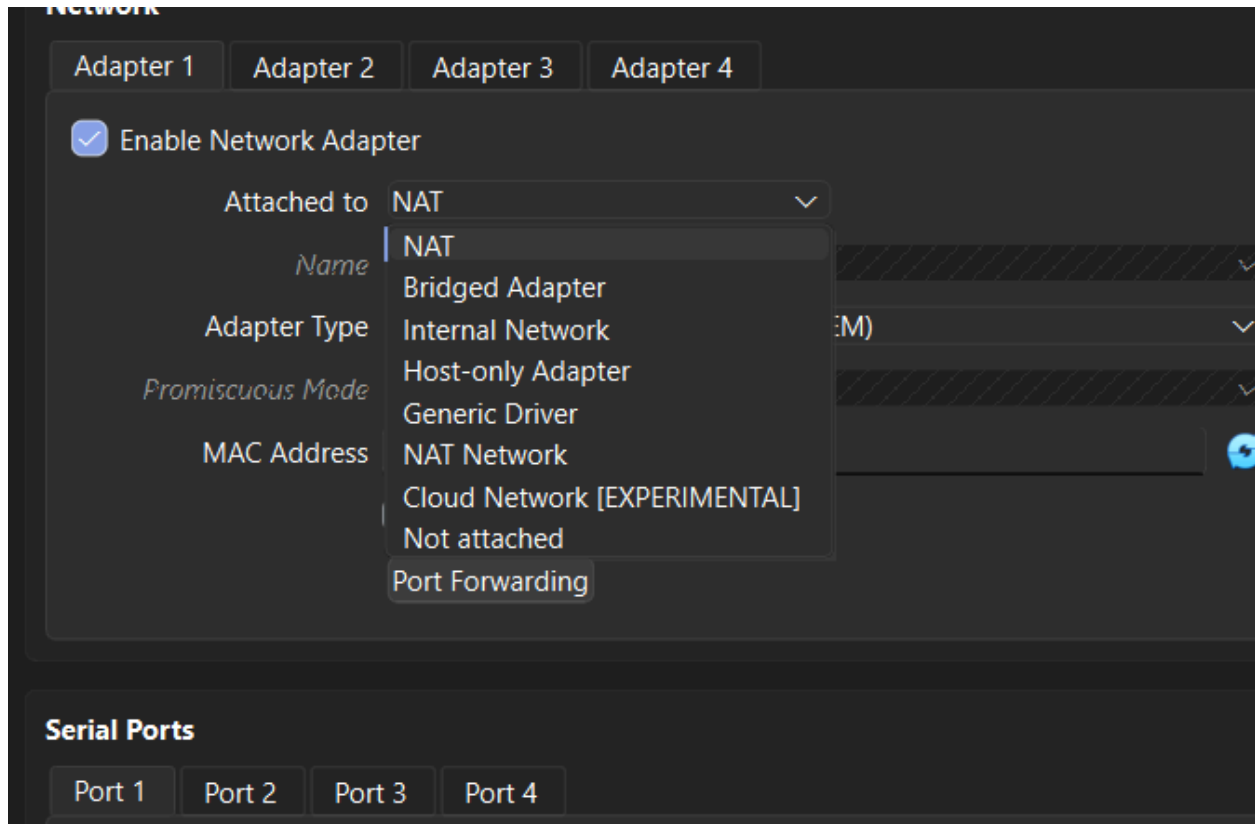
5. Configuración del laboratorio

Para la simulación se utilizó el sistema operativo Kali Linux. Se preparó un archivo HTML local configurado para simular un portal de autenticación básico. Posteriormente, se utilizó la herramienta Social-Engineer Toolkit (SET) mediante el módulo *Credential Harvester Attack Method* usando la opción *Custom Import* para cargar la página web desarrollada y levantar el servidor de escucha en la dirección IP local.

6. Evidencias y descripción del funcionamiento

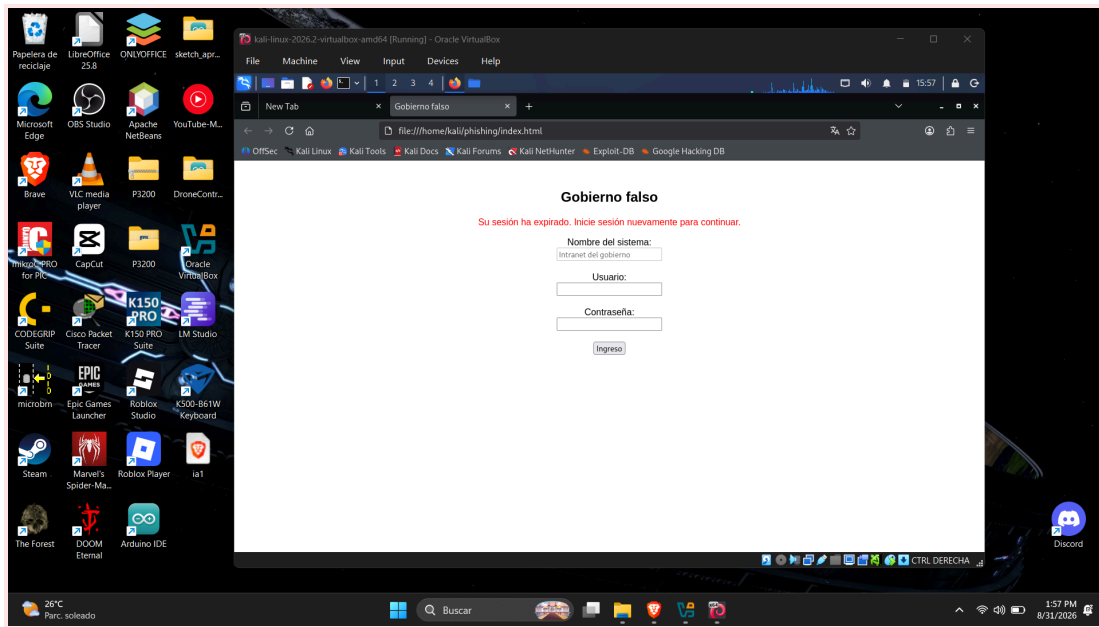
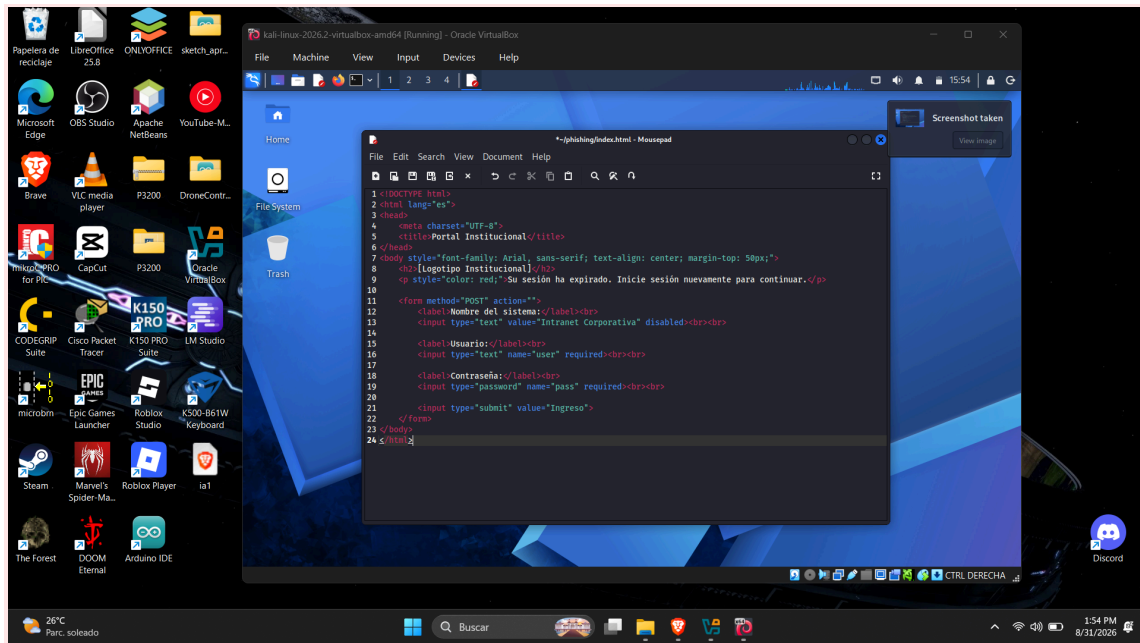
- Configuraciones previas

Cargamos la máquina virtual proporcionada por el profesor, lo que haremos a continuación es conectar nuestra maquina virtual a nuestra subred creada para las pruebas, asinamos el adaptador “bridged adapter” y verificamos con “ifconfig en la consola”



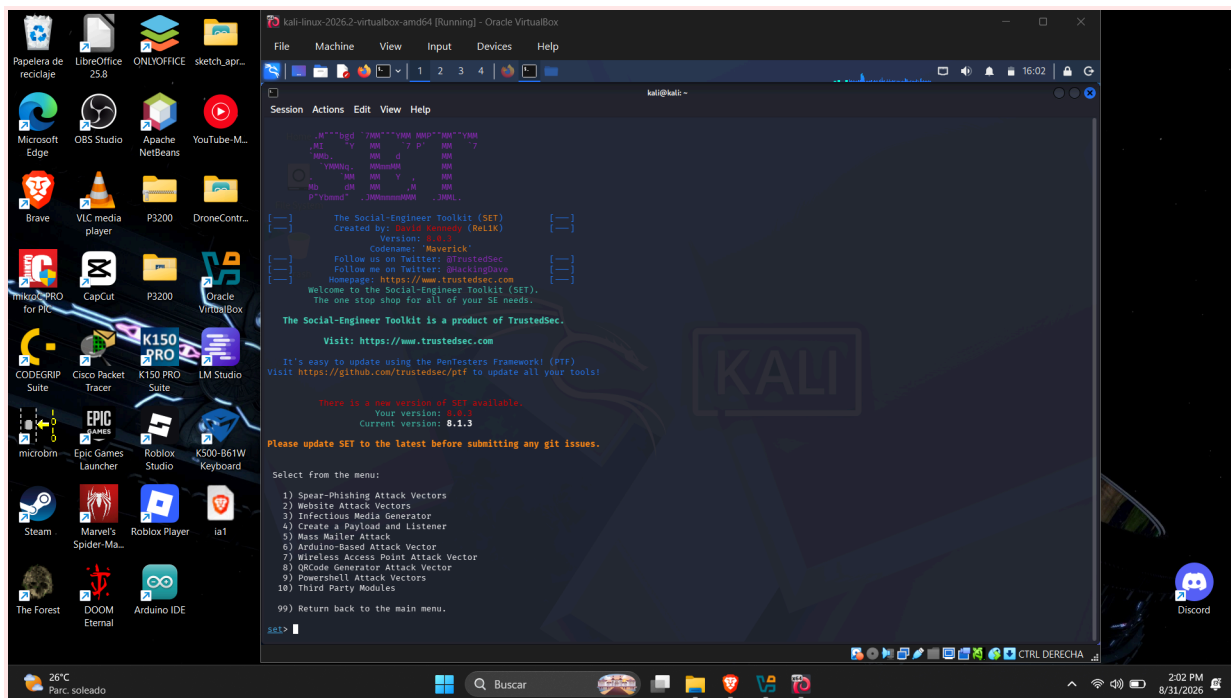
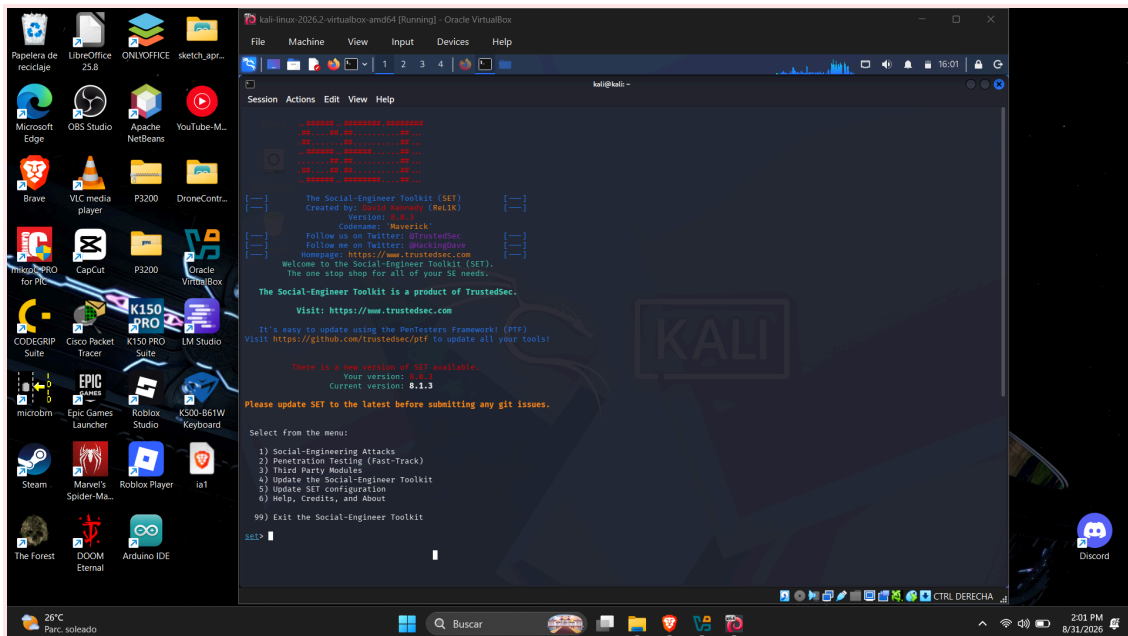
Paso 1: Diseño de la página web (index.html)

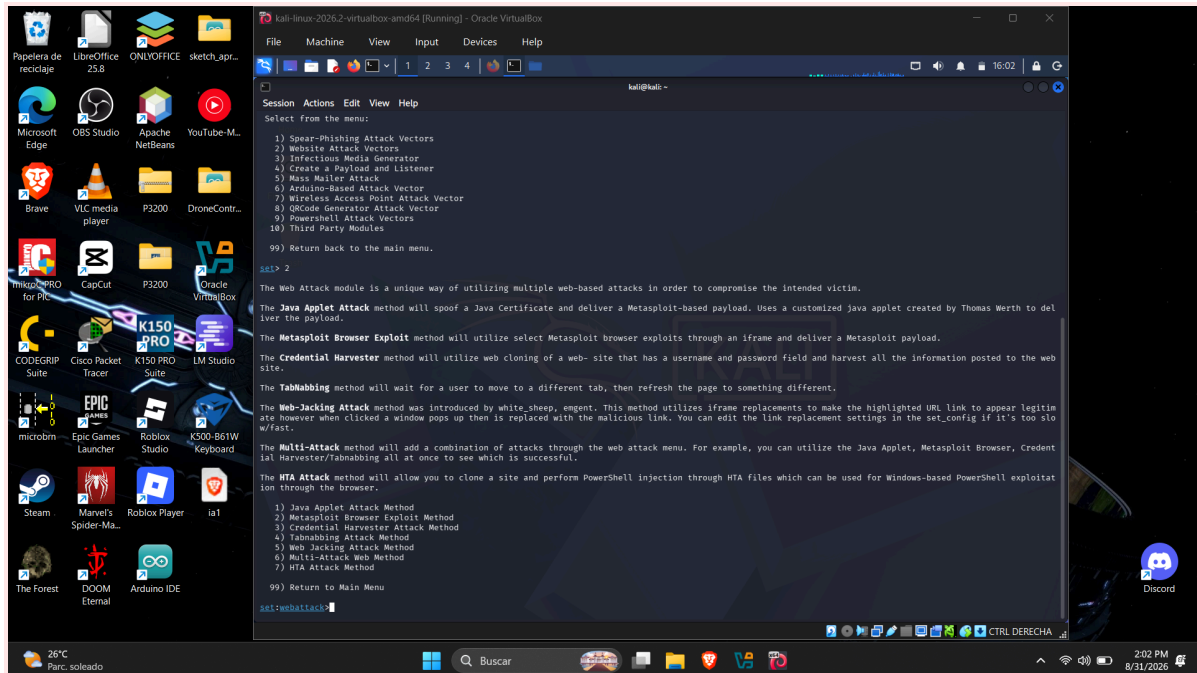
Se desarrolló el código HTML para simular el portal institucional.



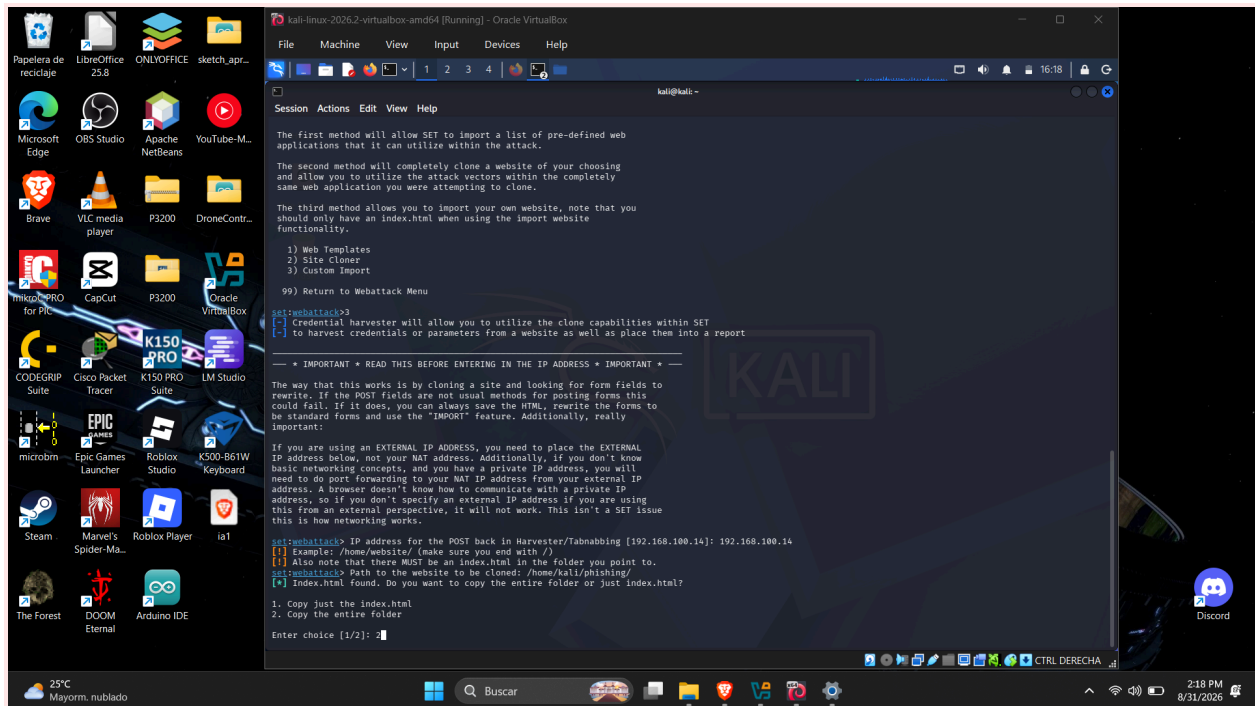
Paso 2: Configuración de SET

Ejecución de setoolkit y selección de los menús para configurar el Credential Harvester con importación personalizada.





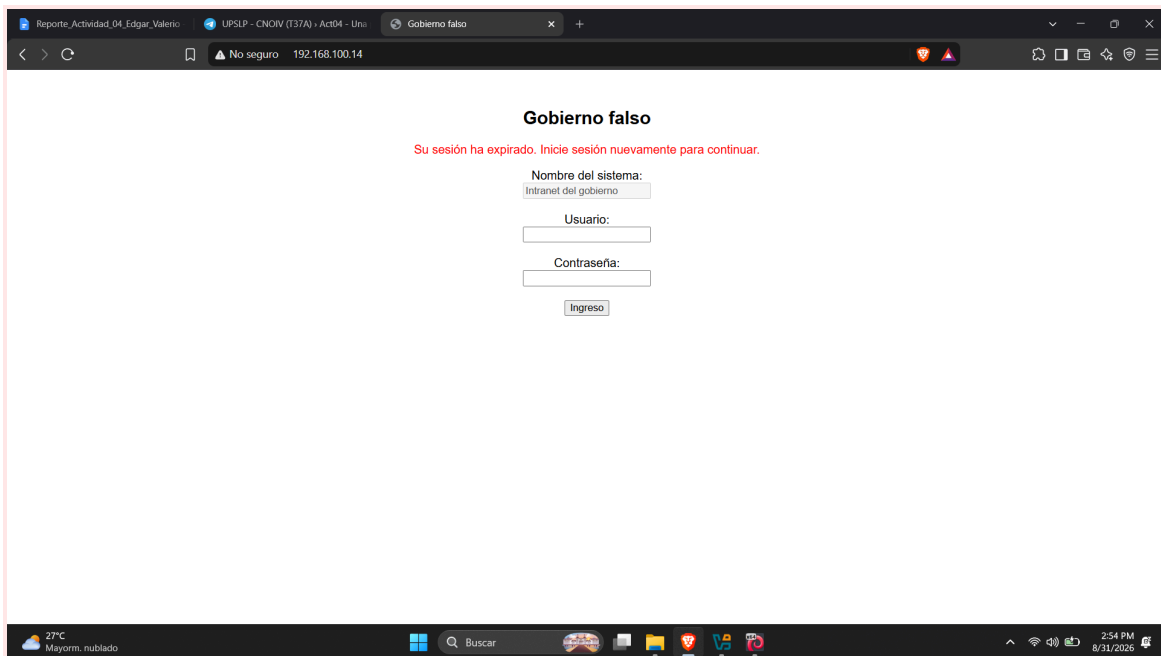
- Una vez entrando a custom import usaremos la ip de nuestra máquina virtual como un servidor



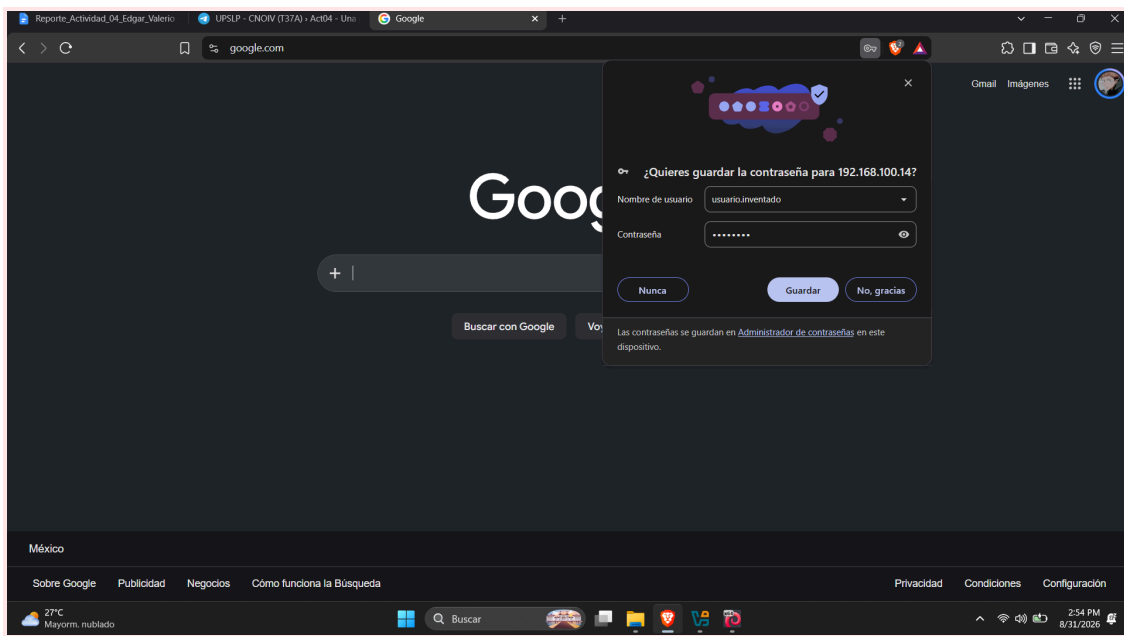
Paso 3: Simulación del ataque

Acceso al portal falso desde el navegador introduciendo credenciales ficticias. En este paso

cualquier dispositivo dentro de nuestra red ya sea alámbrico o inalámbrico es accesible a nuestro servidor

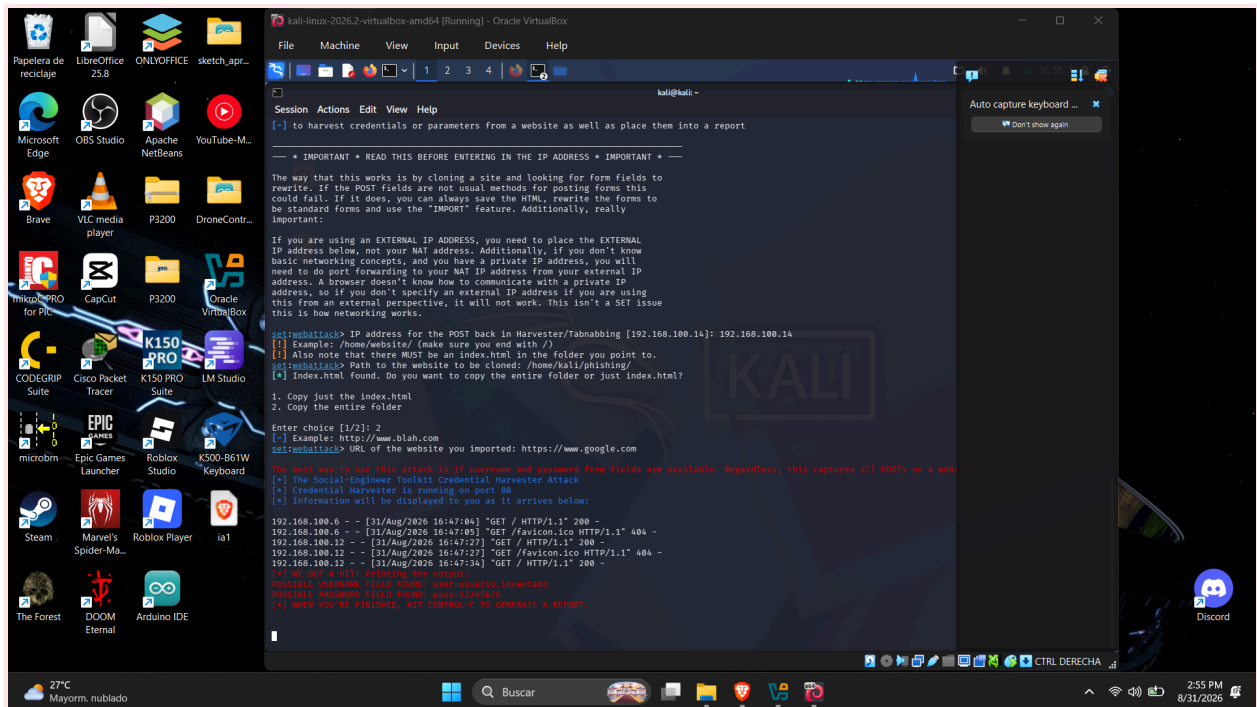


Como anteriormente vimos, al enviar el formulario redirigimos la página a una real para que el ataque sea más creíble (recordando que estamos en un ambiente aii)



Paso 4: Captura de credenciales

Registro de las credenciales interceptadas por SET en la terminal (POSSIBLE CREDENTIAL HARVESTER FOUND).



7. Explicación del flujo de captura de información

El recorrido de la información desde el formulario hasta SET es el siguiente:

1. El usuario interactúa con el formulario HTML local en su navegador e ingresa sus datos (usuario y contraseña).
2. Al presionar el botón de ingreso, el navegador genera una petición **HTTP POST** dirigida al servidor local que fue levantado por SET.
3. El servidor de SET intercepta esta petición HTTP. Extrae los parámetros específicos enviados por el formulario (los campos `name="user"` y `name="pass"`).
4. SET registra estos parámetros en texto plano en su terminal y los almacena en un archivo local para el atacante.
5. Finalmente, SET ejecuta una redirección automática para disimular la captura de información.

Nota: Este ataque consiste en la captura de credenciales por engaño directo y recolección de los datos enviados voluntariamente por el usuario, no en la vulneración técnica (como fuerza bruta o descifrado) de una contraseña almacenada en una base de datos.

Indicadores técnicos y visuales de phishing

- **URL sospechosa:** Uso de una dirección IP cruda o un dominio que simula ser el legítimo mediante errores tipográficos.
- **Falta de cifrado:** Ausencia de un certificado TLS/SSL válido (el navegador indica "No seguro" al usar HTTP en lugar de HTTPS).
- **Tono coercitivo:** Mensajes que imponen urgencia y obligan a la acción inmediata ("Su sesión ha expirado").
- **Diseño visual inconsistente:** Elementos genéricos, tipografía incorrecta o imágenes de baja calidad que no corresponden con la imagen corporativa real.
- **Redirecciones anómalas:** Enlaces internos o de ayuda en la página que no apuntan a ningún sitio o que simplemente recargan la misma página.

8. Controles de seguridad propuestos

Para prevenir o reducir el impacto de estos ataques, se proponen los siguientes cinco controles:

Control de Seguridad	Justificación y Alcance
1. Autenticación Multifactor (MFA)	Mitiga el impacto de las credenciales robadas al requerir un token dinámico o aprobación secundaria. Limitación: No evita el engaño inicial, pero inutiliza el acceso al atacante sin el segundo factor.
2. Gestores de contraseñas corporativos	Protegen a los usuarios al negarse a autocompletar credenciales si la URL del portal fraudulento no coincide exactamente con los registros del dominio oficial almacenado.
3. Filtros Anti-Phishing en correo electrónico	Analizan y bloquean correos con enlaces hacia IPs directas o dominios de baja reputación antes de que lleguen al buzón del empleado, reduciendo significativamente la exposición al riesgo.

Control de Seguridad	Justificación y Alcance
4. Monitoreo de tráfico perimetral	Detecta y alerta sobre conexiones HTTP/HTTPS anómalas hacia IPs no autorizadas para alojar portales de autenticación.
5. Capacitación en Security Awareness	Entrenar continuamente al personal para no hacer clic en enlaces no solicitados e identificar visualmente las señales de fraude. Es el control fundamental de prevención a nivel de usuario.

9. Conclusión

A través de esta simulación práctica, se evidenció la facilidad y rapidez con la que se puede montar un escenario de ingeniería social altamente persuasivo utilizando el Social-Engineer Toolkit (SET). Observar en tiempo real cómo se interceptan credenciales en texto plano subraya que el eslabón más débil en la ciberseguridad sigue siendo el factor humano. Esta actividad reafirma que, más allá de configurar infraestructuras tecnológicas robustas, es indispensable promover la concientización continua de los usuarios (Security Awareness) y adoptar medidas complementarias como la autenticación multifactor (MFA) para mitigar los riesgos de ataques de phishing orientados a comprometer el acceso institucional